

SECURITY

Security

Revision: 2 Last modified: 2026-08-09T00:00:00Z

This document defines the threat model, credential-handling rules, and scanner stack for qBittorrent-Fixed. It complements the constitution (`.specify/memory/constitution.md`, Principle III — Credential & Secret Security, and Principle VIII — IPTorrents Freeleech Policy).

Threat model

Actor	Asset at risk	Mitigation
Public internet	WebUI on :7185	Bound to host network; constitution III mandates credential change before exposing beyond LAN. Reverse-proxy with basic auth or VPN is the operator's responsibility.
Local users on host	<code>.env</code> , <code>~/.qbit.env</code>	File-system ACLs; <code>.env</code> is <code>rw-----</code> . Gitleaks in CI catches leaked commits.
Malicious plugin	Merge service process	Plugins run in a subprocess with a 10-second timeout. A crashing plugin cannot crash the orchestrator. Phase 2

Actor	Asset at risk	Mitigation
Credential capture in logs	Tracker username/password/cookies	moves to ProcessPoolExecutor with resource limits. Logger never formats credentials; env vars are read directly, never serialised to logs.
CSRF / XSS against WebUI	qBittorrent WebUI (admin/admin)	Known-issue: WebUI credentials are hardcoded admin/admin per constitution III. Operator must change on first deploy and not expose the service publicly.
Stolen SSE stream	Live search results on :7187	/api/v1/search/stream requires the search_id returned by POST (unguessable UUID); an attacker still needs to race the search initiator. Phase 3 adds per-client bearer tokens.
Downgrade / replay	Tracker cookies in session storage	In-memory dict _tracker_sessions; cookies never persisted to disk. Phase 2.3 adds Fernet-at-rest encryption for saved cookies — status: pending.
Supply-chain	Python / Node.js / container deps	Dependency audit + SAST + secret scan via the seven-

Actor	Asset at risk	Mitigation
		scanner stack (docs/SCANNING.md).

Credential storage

- **Env vars only.** No credential lands in config/ that is not immediately re-readable from the environment.
- **Priority order** (highest first): shell env → ./env → ~/.qbit.env → container env block. Later sources do *not* override earlier ones.
- **qBittorrent WebUI login** is saved to config/download-proxy/qbittorrent_creds.json when the user checks “Remember me”. The file is rw----- and gitignored.
- **Tracker sessions** (_tracker_sessions dict in download-proxy/src/merge_service/search.py) are in-memory. They evaporate on container restart. Phase 2.3 will persist them encrypted with Fernet — the spec is written but the implementation is **pending**.

admin/admin default

Per constitution Principle III, the WebUI and the proxy default to admin/admin so fresh deploys are immediately usable on a trusted LAN. This is **intentional** and documented. The project’s .gitleaks.toml allowlists the literal admin:admin pair so the secret scanner does not fire on documentation that shows it.

Mitigation when exposing the service beyond LAN:

1. Run init-qbit-password.sh to set a strong qBittorrent password.
2. Update .env with QBITTORRENT_USER / QBITTORRENT_PASS.
3. Rebuild-reboot (CLAUDE.md mandate).
4. Front the stack with a reverse proxy requiring its own auth.

Allowed origins

The FastAPI app currently sets:

```
CORSMiddleware(allow_origins=["*"])
```

at `download-proxy/src/api/__init__.py:68`. This is knowingly over-permissive to ease local development. Phase 3 of the completion-initiative plan tightens it to a configurable allowlist driven by the `ALLOWED_ORIGINS` env var (comma-separated).

CAPTCHA handling

RuTracker periodically presents a CAPTCHA on login. The merge service proxies it through the `/api/v1/auth/rutracker/*` endpoints in `download-proxy/src/api/auth.py`:

- `GET /auth/rutracker/status` — returns whether a session cookie exists.
- `GET /auth/rutracker/captcha` — fetches the current CAPTCHA image from RuTracker, stores the challenge under a random token in the in-memory `_pending_captchas` dict, returns the image as base64 with the token.
- `POST /auth/rutracker/login` — user submits the token + the decoded text; the service replays the login.
- `POST /auth/rutracker/cookie` — user pastes a browser cookie directly (bypasses CAPTCHA for headless operation).

Pending challenges live in `_pending_captchas` with no TTL — Phase 3 replaces this with a TTL cache to prevent memory growth.

IPTorrents freeleech policy (constitution VIII)

Automated tests and downloads **MUST** only use IPTorrents results flagged `freeleech`. A freeleech result is displayed as `IPTorrents [free]` in the `tracker-display` field of `SearchResult`. Non-freeleech downloads **cost ratio** and are never triggered by automation.

Enforcement:

- `download-proxy/src/merge_service/search.py::_parse_iporrents_html` detects `class="free"` and sets `SearchResult.freeleech = True`.
- The deduplicator refuses to merge non-freeleech IPTorrents results with results from other trackers (`download-proxy/src/merge_service/deduplicator.py`).
- `tests/unit/test_freeleech.py` guards the rules.

Scanner stack

Seven scanners cover dependencies, SAST, secrets, and quality. Details in [SCANNING.md](#):

- `pip-audit` — Python runtime deps.
- `bandit` — Python SAST.
- `ruff` — lint + async/security rules.
- `semgrep` — multi-language SAST.
- `trivy` — filesystem CVE + misconfig + secret.
- `gitleaks` — git-history secret scan.
- `snky` — commercial dep + SAST (needs token).
- `sonarqube` — quality gate upload (via opt-in compose).

All run locally via `scripts/scan.sh` and in CI (`.github/workflows/security.yml`). Reports land under `artifacts/scans/<UTC timestamp>/`.

Waiver policy

Any `.snky ignore`, `.trivyignore` entry, or `semgrep inline-disable` **must** carry:

1. Finding ID / CVE / rule ID.
2. Reason.
3. Expiry date (# `expires: YYYY-MM-DD`).

`tests/unit/test_scan_config.py` enforces this against `.trivyignore.yaml`: it fails the build on any entry that is missing an expires date, carries a malformed date, has expired, or uses a template-placeholder CVE id instead of a real one (RD2-06 / RD2-38).

Triage SLOs

- **Critical** — blocks merge; same-day fix or file a CVE-waiver PR.
- **High** — blocks release; fix in current sprint.
- **Medium** — tracked in `ISSUES.md`; opportunistic.
- **Low / info** — documented, ignored unless it bleeds into higher.

Known gaps (pending)

- Fernet-at-rest for tracker cookies — Phase 2.3.
- Allowed-origin allowlist — Phase 3.

- TTL on `_pending_captchas` — Phase 3.
- Bearer-token per-client SSE — Phase 3.
- Per-subprocess resource limit (`ulimit`, `prlimit`) for plugin execution — Phase 2.

Related documents

- [`SCANNING.md`](#) — scanner invocation and CI integration.
- [`QUALITY\_STACK.md`](#) — opt-in compose file.
- [`CONCURRENCY.md`](#) — graceful shutdown and retry behaviour that interacts with security.
- [`../.specify/memory/constitution.md`](#) — Principles III and VIII.